

arxdsilva
@arxdsilva

How to protect an internal admin tool: good, better, best.

Shubham Shah and Sam Curry unlocked an automaker's cars from just a number plate.

The way in was an internet-facing admin tool called **TEST HARNESS** .



arxdsilva

@arxdsilva

Even the best level leaves the app's own APIs public.

Which level is your admin tool on? Save this.

- Good: WAF rules. An encoded URL got past.
- Better: auth on every API. A leaked key undoes it.
- Best: reachable only through a VPN.